

1. Definition:

Security risk management in IT Service Management is the process of identifying, assessing, prioritizing, and controlling IT security-related risks to protect IT assets, data, and services from threats.

- **For example:** A bank applies Security Risk Management to assess the risk of customer data leakage and implements DLP and MFA to mitigate the risk.

2. Purpose of use:

- Early identification and control of security risks.
- Supporting strategic decision-making and efficient resource allocation.
- Meets compliance requirements (ISO 27001, NIST RMF, COBIT, GDPR, PCI-DSS)

3. Application steps and practical examples:

Context: An e-commerce company stores millions of customer records.

- **Step 1: Identify assets and threats**
 - Examples: Customer databases, payment systems, ransomware, phishing.
- **Step 2: Risk Assessment**
 - Example: High probability of risk + serious impact $\rightarrow$ Critical Risk
- **Step 3: Determine the control measures (Risk Treatment)**
 - Examples: Implementing SIEM, IAM, encryption, and employee training.
- **Step 4: Continuous monitoring and review**
 - Example: Quarterly risk report for the CISO and Board of Directors
- **Step 5: Update the Risk Register and continuously improve it.**

4. Practical considerations:

- Risk cannot be completely eliminated, only managed and mitigated.
- It must be aligned with business strategy and governance.
- There should be clear Risk Appetite and Risk Tolerance information.

5. Illustrative examples:

- **Basic:** Assess email system risks and implement SPF/DKIM/DMARC.
- **Advanced:** Build an enterprise-wide Risk Register integrating ITSM, GRC, and SIEM.

6. Case Study Mini:

- **Situation:**A hospital was fined for violating HIPAA after a patient data leak.
- **Solution:**Implement Security Risk Management with periodic assessments and DLP, IAM measures.
- **Result:**Reduce data leak risk by 75% and achieve compliance within 9 months.

7. Quick Quiz:

What is the goal of Security Risk Management in ITSM?

- a. **Identify, assess, and control security risks** $\rightarrow$
- b. Reduced transparency in management
- c. Only address problems after they have occurred.
- d. Ignoring compliance to save costs.

8. Scenario-Based Question:

If your company is preparing to launch a new cloud service, how would you implement Security Risk Management to mitigate security risks?

9. Why should you care about this concept?

- Security risks are the top threat to any digital business.
- Effective risk management helps protect data, reputation, and competitive advantage.

10. Practical applications in the workplace:

- **IT & Security:**Conduct a risk assessment and propose controls.
- **Compliance:**Ensure that risks are managed according to international standards.
- **Management team:**Approve Risk Appetite, prioritize resources.
- **Risk Manager:**Maintain a Risk Register and monitor Key Risk Indicators (KRIs).

11. Common mistakes during implementation:

- Risk assessment is a one-time assessment, not a continuous one.
- Focus on technology, ignore people and processes.
- Do not link security risks to business strategy.

12. Applicable subjects:

- Dành cho: CIO, CISO, Risk Manager, Compliance Officer, Board of Directors.

- Applicable to: Medium and large organizations, especially in the finance, healthcare, telecommunications, and e-commerce sectors.

13. Simple and easy-to-understand introduction:

Security Risk Management in ITSM is like this: "**flood prevention map**"– Identify risk areas and implement protective measures before an incident occurs.

14. Frequently Asked Questions:

- **Q1: How is Security Risk Management different from Incident Management?**
 - Incident Management deals with incidents after they have occurred, while Risk Management focuses on prevention.
- **Q2: How often should a risk assessment be conducted?**
 - At least annually, or whenever there are major changes.
- **Q3: Who is primarily responsible?**
 - CISO and Risk Manager, under the supervision of the Board of Directors.